

First Unfamiliar Target

Spaced Recall

Exposure vs weakness vs vulnerability:

- Exposure: something is reachable or available
- Weakness: something about configuration/design reduces security
- Vulnerability: a weakness that can be exploited/abused creating security impact

Why couldn't we declare an SMB vulnerability merely because 445 was open?

This shows exposure, we still need to assess.

Security+ Lesson 4

Threat Actors, Motivations, Attack Surface & Attack Vectors

Part 1: What is a threat actor?

A threat actor is the person, group, organization, or entity responsible for potentially malicious activity. The important question isn't only: Who are they?

It's: What does who they are tell me about their likely capability, motivation, targets, resources, and persistence?

Two attackers can use the same technique while representing completely different risks.

Nation-state actors

Nation-state or state-sponsored actors operate on behalf of, or in support of, government objectives

Motivations: espionage, intelligence collection, military objectives, strategic advantage, intellectual-property theft, disruption, influence

They may have: significant funding, skilled personnel, long time horizons, access to sophisticated tooling, willingness to maintain persistence for months or years

Imagine: an attacker spends six months quietly maintaining access inside a defense contractor. That behavior makes more sense for long-term intelligence collection than someone trying to make \$500 quickly.

Lesson: Actor context changes your expectations.

Organized cybercrime

Groups generally financially motivated

Example objectives: steal credentials -> steal money, deploy ransomware -> demand payment, steal data -> extortion, compromise accounts -> fraud

Hacktivists

Commonly driven by: political causes, social causes, ideology, publicity

Possible activity: website defacement, information leaks, denial of service, account compromise

Motivation helps explain target selection

Insider threats

The attacker may already possess legitimate access, an insider could be:

1. Malicious: someone intentionally abuses legitimate access
 - a. Employee steals confidential company information before leaving
2. Negligent: someone causes security problems without malicious intent
 - a. Employee sends sensitive data to the wrong recipient
3. Compromised Insider: A legitimate user's account/device gets compromised by an external attacker
 - a. Valid employee account activity does not automatically mean legitimate employee activity

Unskilled / low-sophistication attackers

Referred to casually as "script kiddies"

Rely heavily on: public exploit code, automated scanners, tutorials, tools built by others

Limited sophistication doesn't mean zero danger; if an organization has a trivial known vulnerability, an unsophisticated attacker may still exploit it

Competitors

A competing organization may have motivations involving: intellectual property, strategy, market advantage, confidential business information

Shadow IT

Technology employees use without appropriate organizational approval or management

Ex: Employee needs file sharing -> Creates personal cloud-storage account -> Uploads company documents

Employee may be trying to work efficiently, but now security may lack: visibility, access control, data governance, monitoring, retention controls

Part 2: Motivation

Threat actor and motivation are related but not identical. A threat actor answers: Who?

Motivation answers: Why?

Common motivations: Financial gain, espionage, data theft, political/ideological goals, revenge, disruption, competitive advantage, recognition/status

Why does a defender care? Because motivation influences expected behavior. Someone operating ransomware may prioritize: rapid privilege escalation -> data theft -> mass encryption -> extortion

An espionage actor may prioritize: quiet foothold -> credential access -> persistence -> long-term collection

Part 3: Attack Surface

Attack surface is the collection of potential points an attacker can interact with...for a server: network services, applications, accounts, APIs, remote administration, credentials, operating system, trust relationships

Part 4: Attack vector

An attack vector is the method/path used to attempt compromise or abuse. Example: public login portal can be part of the attack surface. Using stolen credentials against that portal is an attack vector.

Another ex: employee email account exists within the organization's environment. A phishing email carrying a malicious link can be an attack vector.

ATTACK SURFACE: "What could potentially be interacted with?"

ATTACK VECTOR: "How does the attacker attempt to get in or cause harm?"

Quick examples:

Example A: Company exposes VPN access to employees.

VPN Service -> Attack surface

Attacker obtains an employee password through phishing and uses it against the VPN.

Stolen credentials -> Attack vector

Example B: A web application accepts file uploads.

Upload Functionality -> Part of attack surface

An attacker abuses improper file validation to upload dangerous content.

Malicious file upload -> Attack vector

Part 5: Why this matters to vulnerability assessment

Today, receiving an unfamiliar system. Begin by asking: What attack surface can I observe?

Enumeration will help answer that. Then later: Are there plausible attack vectors against anything I've discovered? Then: Is an actual weakness present?

Progression: Attack surface discovery -> Candidate attack vector -> potential weakness -> validation -> actual finding?

Professional Assessment Setup

Today, need an explicitly authorized unfamiliar target.

I am being given: One IP address belonging to a machine I am explicitly authorized to assess, with almost no knowledge of what is running on it.

Goal: Turn MACHINE_IP "I know basically nothing." into: Host -> Open Ports -> Services -> Versions/details -> Understanding of exposed attack surface -> One sensible investigation candidate

<https://tryhackme.com/room/vulniversity>

Task 1: Deploy the machine

Task 1

Deploy the machine



Set up your virtual environment

To successfully complete this room, you'll need to set up your virtual environment. This involves starting both your AttackBox (if you're not using your VPN) and Lab Machines, ensuring you're equipped with the necessary tools and access to tackle the challenges ahead.

Attacker machine

Status: Off

Lab machine

Status: Off

Start Lab Machine

Connect to our network and deploy this machine. If you need help getting connected, complete the [OpenVPN room](#) first.

Note: Please allow the VM 4 - 5 minutes to fully boot.

Answer the questions below

Deploy the machine.

Join this room

Join this room

A slight detour here.....need to do a lesson on OpenVPN; this is to connect to their network.

<https://tryhackme.com/room/openvpn>

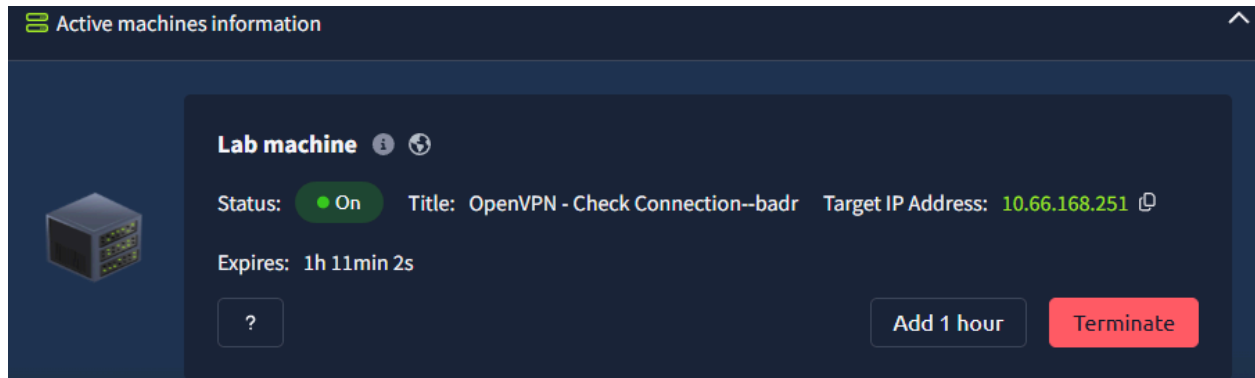
Downloading the OpenVPN client plus the .ovpn file.

Commands:

- 1: `sudo apt update`
- 2: `sudo apt install openvpn -y`
- 3: `openvpn --version` (This is confirmation we installed)

Downloaded the .ovpn file. Run: **`sudo openvpn .ovpn_file_name`**

Now we can start the TryHackMe Machine!



Ping this IP address to test connectivity. Go to <http://10.66.168.251> to get what's on the webpage.

That was the test one; I have now deployed the machine.

SO: we are authorized to assess: 10.66.168.251. Today's allowed behavior is:

- Connectivity testing
- TCP port scanning
- Service/version detection
- Basic service interaction
- Web browsing if a web service is discovered
- Researching what discovered technologies do

Useful command: `sudo killall openvpn` (ends all openvpn processes)

Connectivity Check

Ask: Can my attacker machine actually communicate with the assigned lab target?

Ping is the command to check reachability. If ICMP doesn't answer, cannot immediately conclude the target is broken.

```
(nigist@kali)-[~]
$ ping -c 4 10.66.162.180
PING 10.66.162.180 (10.66.162.180) 56(84) bytes of data:
64 bytes from 10.66.162.180: icmp_seq=1 ttl=62 time=13.5 ms
64 bytes from 10.66.162.180: icmp_seq=2 ttl=62 time=14.1 ms
64 bytes from 10.66.162.180: icmp_seq=3 ttl=62 time=17.8 ms
64 bytes from 10.66.162.180: icmp_seq=4 ttl=62 time=12.9 ms
--- 10.66.162.180 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3004ms
rtt min/avg/max/mdev = 12.870/14.561/17.803/1.921 ms
```

Network is reachable.

Plan Before Scanning

What TCP ports on this unfamiliar system are remotely exposed?

Can do nmap's normal scan or the full TCP range....I believe the command is nmap -p-IP_address

```
(nigist@kali)-[~]
└─$ nmap -p- 10.66.162.180
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-09-01 21:06 EDT
Nmap scan report for 10.66.162.180
Host is up (0.031s latency).
Not shown: 65529 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3128/tcp  open  squid-http
3333/tcp  open  dec-notes
Nmap done: 1 IP address (1 host up) scanned in 10.42 seconds
```

Some service version detection for those ports:

```
(nigist@kali)-[~]
└─$ nmap -sV -p 21,22,139,445,3128,3333 10.66.162.180
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-09-01 21:07 EDT
Nmap scan report for 10.66.162.180
Host is up (0.015s latency).
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.5
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
139/tcp   open  netbios-ssn Samba smbd 4.6.2
445/tcp   open  netbios-ssn Samba smbd 4.6.2
3128/tcp  open  http-proxy   Squid http proxy 4.10
3333/tcp  open  http         Apache httpd 2.4.41 ((Ubuntu))
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 22.28 seconds
```

We know that the -Pn command is good for ignoring host discovery. Could use this if needed since we know the machine is reachable. Don't need to, since no trouble yet.

Enumeration Round 1

Port	State	Version/details	What does this do?	What do I want to know next?
21	open	Ftp (vsftpd 3.0.5)	Ftp stands for file transfer protocol, its job is to basically let a client connect to a server and upload, download, list, rename, or delete files. Vsftpd stands for Very Secure FTP Daemon. "Daemon" is just a background service on Linux.	More understanding of how FTP works on a system day-by-day and what possible weaknesses it has
22	open	Ssh (OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 Ubuntu Linux; protocol 2.0)	SSH = Secure Shell, lets you remotely log into and control another computer over an encrypted connection.	When do you know SSH is weak, how does the encryption work?
139	open	Netbios-ssn (Samba smbd 4.6.2)	Port 139 is the older SMB-over-NetBIOS	
445	open	Netbios-ssn (same as above)	Modern port for SMB.	Begin enumerating, understand SMB differences in Ubuntu, since the target OS is ubuntu
3128	open	Http-proxy (Squid http proxy 4.10)	Commonly used by an HTTP proxy server, http proxy sits between a client and the	

			website/server it wants to reach. Instead of your browser connecting directly to example.com , it can send the request to the proxy, and the proxy makes the request on your behalf	
3333	open	http	HTTP web server, can access this by using <code>http://10.66.162.180:3333</code>	Explore website

Lets say I encounter a service I've never seen. The questions to ask are:

1. What is this protocol/application?
2. What is its legitimate purpose?
3. Who normally interacts with it?
4. Does it provide remote administration, file transfer, web content, database access, etc?

Observations vs Inferences vs Unsupported claims